

DEFENSIVE OPERATIONS PLAYBOOK

부동산 웹사이트 보안·장애·유지보수 대응 가이드

DDoS, 해킹, 계정 탈취, 서비스 장애, 데이터 손상,
잘못된 배포에 빠르게 대응하기 위한 실무 훈련 문서

PREVENT	DETECT	RESPOND	RECOVER
안전한 설계	로그와 경고	차단과 통제	복구와 학습

00 운영 철학과 안전 원칙

이 프로젝트의 성공 기준은 기능 수가 아니라 문제를 예방하고, 빠르게 발견하고, 안전하게 복구하며, 같은 문제의 재발을 줄이는 능력이다.

핵심 흐름

예방 -> 탐지 -> 분류 -> 차단 -> 복구 -> 원인 분석 -> 재발 방지

안전한 훈련 원칙

- 공격과 장애 주입은 격리된 개발·스테이징 환경에서만 수행한다.
- 외부 서비스와 실제 사용자, 허가받지 않은 네트워크를 대상으로 시험하지 않는다.
- 실제 개인정보와 운영용 인증정보를 훈련 데이터로 사용하지 않는다.
- 훈련 전에 중단 조건, 복구 방법, 담당자를 정하고 백업 복원을 확인한다.
- 결과를 자동 테스트, 알림 규칙, 런북에 반영한다.

핵심 측정 지표

지표	측정 대상
MTTD	문제 발생부터 탐지까지
MTTA	경고부터 담당자의 대응 시작까지
MTTR	탐지부터 정상 복구까지
변경 실패율	배포가 장애·긴급 수정·롤백으로 이어진 비율
복원 성공률	백업을 실제로 복원하고 검증한 비율
재발률	이미 해결한 유형이 다시 발생한 비율

01 심각도와 최초 15분

등급	대표 상황	최초 확인	핵심 행동
SEV-1	전체 중단, 유출 의심, 관리자 탈취, 데이터 파괴	5분	책임자 지정, 확산 차단, 증거 보존, 복구
SEV-2	주요 기능 중단, 심각한 지연, 외부 API 장애	15분	우회·기능 제한, 원인 분석, 영향 공지
SEV-3	제한적 오류, 운영 우회 가능한 결함	업무시간	작업 등록, 일정 지정, 회귀 테스트
SEV-4	경미한 UI·문서·개선 요청	계획 주기	우선순위 평가 후 정기 배포

최초 15분 체크리스트

- 사건 번호와 발생·탐지 시각을 기록한다.
- 심각도와 사용자 영향을 판단한다.
- 대응 책임자 한 명과 기록 담당자를 지정한다.
- 확산을 막는 가장 안전한 차단 조치를 선택한다.
- 로그·감사·배포 기록을 삭제하지 않고 보존한다.
- 마지막 배포·설정·관리자 작업·트래픽 변화를 확인한다.
- 롤백, 읽기 전용, 기능 플래그 차단, 요청 제한을 준비한다.
- 모든 조치와 결과를 시간순으로 남긴다.

주의

위 시간은 운영 약속이 아니라 프로젝트 훈련을 위한 초기 목표다. 실제 인력과 서비스 수준에 맞춰 조정한다.

02 보안 공격과 침해 상황

공격 기술을 재현하는 것이 목적이 아니라, 방어 시스템이 탐지하고 운영자가 안전하게 차단·복구할 수 있는지 검증하는 것이 목적이다.

S-01 DDoS와 대량 트래픽 공격

발생 가능 원인	봇넷 요청, 특정 검색·이미지 URL 집중 호출
탐지 징후	요청 수·네트워크·429·5xx·비용 급증
예상 영향	접속 불가, 정상 사용자 차단, 비용 증가
즉시 대응	CDN/WAF/요청 제한 강화, 공격 경로 차단, 점검 화면, 인프라 지원 요청
예방·훈련	캐시, 자동 확장 한도, 비용 경고, 격리 환경 부하 시험

S-02 로그인 무차별 대입과 크리덴셜 스테핑

발생 가능 원인	유출 계정 목록 재사용, 자동 비밀번호 대입
탐지 징후	반복 실패, 동일 IP·기기의 다계정 시도, 성공 후 정보 변경
예상 영향	계정 탈취, 매물 조작, 개인정보 열람
즉시 대응	추가 인증, 의심 세션 종료, 영향 계정 재설정, 로그 보존
예방·훈련	MFA, 유출 비밀번호 차단, 위치·기기 이상 탐지

S-03 계정 탈취와 세션 도용

발생 가능 원인	피싱, 토큰 유출, 공용 기기, 악성 확장
탐지 징후	새 위치 로그인, 연락처·가격·계좌 정보 급변
예상 영향	사기성 매물, 문의 정보 유출, 관리자 권한 악용
즉시 대응	전체 세션 폐기, 잠금, 본인 확인, 변경 복구, 토큰 교체
예방·훈련	짧은 세션, 보안 쿠키, 중요 변경 재인증, MFA

S-04 권한 검증 실패와 IDOR

발생 가능 원인	ID 변경만으로 타인의 매물·문의에 접근
탐지 징후	소유자가 아닌 계정의 조회·수정, 연속 ID 탐색
예상 영향	타인 매물 수정, 개인정보 노출, 관리자 기능 오용
즉시 대응	취약 API 중단, 객체 소유권 검사, 영향 범위 조사
예방·훈련	서버측 객체 권한, 역할별 통합 테스트, 거부 경고

S-05 SQL 삽입

발생 가능 원인	입력값을 쿼리 문자열에 직접 연결
탐지 징후	SQL 오류, 특수 패턴 반복, DB 부하·대량 조회
예상 영향	데이터 열람·변경, DB 장애
즉시 대응	입력 경로 차단, WAF 규칙, DB 자격증명 교체 검토, 로그 보존
예방·훈련	매개변수 쿼리, ORM, DB 최소 권한, 회귀 테스트

S-06 저장형·반사형 XSS

발생 가능 원인	매물 설명·문의 출력 시 안전 처리 누락
탐지 징후	예상 밖 스크립트, 세션 이상, CSP 위반
예상 영향	세션 탈취, 악성 이동, 관리자 화면 공격
즉시 대응	문제 필드 격리, 페이지 비활성화, 세션 폐기, 영향 조사
예방·훈련	출력 인코딩, HTML 허용 목록, CSP, 보안 쿠키

S-07 CSRF

발생 가능 원인	로그인 사용자의 세션으로 의도하지 않은 변경 요청
탐지 징후	사용자 기억에 없는 수정, 외부 출처의 상태 변경
예상 영향	매물 삭제·가격 변경, 계정 설정 변경
즉시 대응	취약 API 차단, 세션 폐기, 변경 이력 복구
예방·훈련	CSRF 토큰, SameSite 쿠키, Origin 검증

S-08 악성 파일 업로드

발생 가능 원인	실행 파일 위장, 압축 폭탄, 초대형 이미지
탐지 징후	MIME 불일치, 처리 실패, 저장 공간·CPU 급증
예상 영향	악성코드 배포, 자원 고갈, 비용 증가
즉시 대응	파일 격리, 다운로드 중단, 업로드 제한, 관련 계정 조사
예방·훈련	형식·크기 제한, 재인코딩, 악성코드 검사, 별도 저장소

S-09 API 키와 비밀정보 노출

발생 가능 원인	저장소 커밋, 번들·로그·설정 공개
탐지 징후	비정상 API 사용량, 알 수 없는 위치 접근, 검사 경고
예상 영향	비용 증가, DB 접근, 데이터 유출
즉시 대응	키 폐기·교체, 접근 기록 확인, 권한 축소, 배포본 제거
예방·훈련	비밀 저장소, 커밋 검사, 짧은 수명, 사용 범위 제한

S-10 봇·스크래핑과 API 남용

발생 가능 원인	매물 대량 수집, 검색 API 반복 호출
탐지 징후	일정한 순회, 비정상 User-Agent, 과도한 페이지네이션
예상 영향	성능·비용·데이터 무단 수집
즉시 대응	속도 제한, 봇 규칙, 토큰 차단, 무거운 검색 제한
예방·훈련	페이지 크기 제한, 캐시, 행위 탐지, 사용량 경고

S-11 공급망과 의존성 침해

발생 가능 원인	악성 패키지, 취약 CI, 위조 빌드
탐지 징후	설치 중 외부 통신, 예상 밖 파일, 해시 불일치
예상 영향	서버 장악, 비밀 유출, 악성 코드 배포
즉시 대응	배포 중단, 의심 버전 격리, 자격증명 교체, 재빌드
예방·훈련	잠금 파일, 의존성 검사, SBOM, 재현 빌드

S-12 관리자 악용과 내부자 위험

발생 가능 원인	계정 탈취, 과도한 권한, 사회공학, 실수
탐지 징후	대량 승인·삭제·내보내기, 감사 로그 중단
예상 영향	허위 매물, 개인정보 유출, 정상 데이터 삭제
즉시 대응	권한 회수, 세션 폐기, 이중 승인, 변경 복구
예방·훈련	관리자 MFA, 최소 권한, 중요 작업 이중 승인

S-13 랜섬웨어와 대량 데이터 파괴

발생 가능 원인	서버·관리자 침해, 악성 배포, 공유된 백업 권한
탐지 징후	대량 변경·삭제, 백업 실패, 몸값 메시지
예상 영향	장기 중단, 데이터 손실, 개인정보 사고
즉시 대응	네트워크 격리, 쓰기 중단, 증거 보존, 검증 백업 복원
예방·훈련	불변 백업, 네트워크 분리, 삭제 지연, 복원 훈련

S-14 개인정보 유출

발생 가능 원인	공개 저장소, 권한 오류, 로그·내보내기, 침입
탐지 징후	대량 다운로드, 공개 버킷 경고, 개인정보 로그
예상 영향	사용자 피해, 법적 대응, 신뢰 하락
즉시 대응	노출 차단, 증거·범위 보존, 자격증명 교체, 사고 절차 개시
예방·훈련	수집 최소화, 암호화, 마스킹, 다운로드 통제

03 서비스 장애와 성능 상황

사용자 증가와 외부 서비스 장애도 공격과 비슷한 증상을 만들 수 있다. 원인을 단정하지 말고 지표와 변경 이력으로 구분한다.

A-01 정상 트래픽 급증

발생 가능 원인	광고·뉴스·인기 매물로 동시 접속 증가
탐지 징후	요청 수·응답 시간·동시 접속 동반 증가
예상 영향	검색 지연, 이미지 실패, 비용 증가
즉시 대응	캐시, 무거운 기능 제한, 읽기 전용, 확장 한도 조정
예방·훈련	부하 시험, 용량 기준, 비용 경고, 인기 데이터 캐시

A-02 애플리케이션 충돌과 메모리 누수

발생 가능 원인	코드 결함, 대형 이미지, 미해제 객체
탐지 징후	재시작, 메모리 지속 상승, OOM, 특정 요청 후 오류
예상 영향	간헐적 500, 인스턴스 중단
즉시 대응	문제 버전 롤백, 트래픽 분산, 경로 제한, 로그 보존
예방·훈련	자원 지표, 준비·생존 검사, 제한, 장시간 시험

A-03 DB 과부하와 느린 쿼리

발생 가능 원인	인덱스 누락, 과도한 검색, 데이터 증가
탐지 징후	쿼리 시간·CPU·잠금·연결 증가
예상 영향	로그인·검색·등록 전체 지연
즉시 대응	병목 쿼리 중단, 검색 제한, 캐시, 연결 상한 조정
예방·훈련	느린 쿼리 로그, 인덱스 검토, 시간 제한, 규모 시험

A-04 DB 연결 풀 고갈과 교착

발생 가능 원인	연결 누수, 장기 트랜잭션, 높은 동시성
탐지 징후	연결 획득 타임아웃, 최대 연결, 대기 증가
예상 영향	단순 조회까지 연쇄 실패
즉시 대응	장기 작업 종료, 안전한 재시작, 쓰기 제한
예방·훈련	연결 반환, 짧은 트랜잭션, 풀 지표, 동시성 시험

A-05 캐시 장애와 스템피드

발생 가능 원인	캐시 서버 장애, 동일 TTL, 인기 키 만료
탐지 징후	적중률 급락, DB 요청 급증, 동일 키 재계산
예상 영향	DB 과부하와 전체 지연
즉시 대응	오래된 캐시 허용, 요청 병합, 재생성 제한
예방·훈련	TTL 분산, single-flight, 캐시 없는 용량 시험

A-06 이미지 저장소·CDN 장애

발생 가능 원인	원본 장애, 권한·서명 URL 오류, CDN 장애
탐지 징후	이미지 403-404-5xx, 업로드 실패
예상 영향	매물 신뢰도 저하, 등록 실패
즉시 대응	기본 이미지, 업로드 대기열, 권한·원본 확인
예방·훈련	재시도, 멍등성, 저장소 권한과 사용량 감시

A-07 DNS·TLS 인증서 문제

발생 가능 원인	DNS 오설정, 인증서 만료·체인 문제
탐지 징후	도메인 해석 실패, 브라우저 보안 경고
예상 영향	사이트 접속 불가 또는 신뢰 경고
즉시 대응	이전 DNS 복구, 인증서 긴급 갱신, 체인 확인
예방·훈련	만료 경고, 자동 갱신, DNS 변경 승인

A-08 클라우드 리전·네트워크 장애

발생 가능 원인	제공자 장애, 라우팅·네트워크 문제
탐지 징후	여러 서비스 동시 실패, 광범위 타임아웃
예상 영향	전체 또는 지역별 중단
즉시 대응	대체 리전·정적 안내·읽기 전용 전환
예방·훈련	의존성 지도, 백업 위치 분리, 복구 순위 훈련

A-09 지도·문자·이메일 API 장애

발생 가능 원인	외부 공급자 장애, 한도·인증 문제
탐지 징후	특정 공급자 타임아웃, 재시도 증가
예상 영향	주소 검색·인증·문의 알림 실패
즉시 대응	회로 차단, 제한 재시도, 대기열 저장, 기능 제한 안내
예방·훈련	타임아웃 상한, 상태 감시, 대체 입력과 수동 절차

A-10 디스크·로그 공간 고갈

발생 가능 원인	로그 폭증, 보존 오류, 임시 파일 누적
탐지 징후	디스크 경고, 로그·배포·DB 쓰기 실패
예상 영향	충돌과 데이터 손상 가능성
즉시 대응	안전한 로그·임시 파일 정리, 쓰기 제한, 용량 확장
예방·훈련	로그 순환, 보존 기간, 용량 예측과 단계 경고

A-11 작업 큐와 예약 작업 적체

발생 가능 원인	소비자 장애, 실패 재시도 폭주, 처리량 부족
탐지 징후	대기 수와 지연 증가, 만료·알림 처리 지연
예상 영향	오래된 매물 노출, 문의 알림 누락
즉시 대응	실패 격리, 소비자 확장, 안전 확인 후 재처리
예방·훈련	지연 경고, dead-letter 큐, 멍등성, 재처리 런북

04 데이터·배포·유지보수 상황

장애의 상당수는 공격이 아니라 정상적인 변경과 운영 실수에서 시작된다. 변경을 작게 만들고 항상 되돌릴 수 있게 한다.

M-01 실수로 데이터 삭제

발생 가능 원인	관리자 오조작, 잘못된 스크립트
탐지 징후	매물 수 급감, 대량 DELETE, 사용자 신고
예상 영향	매물·문의 기록 소실
즉시 대응	쓰기 중단, 범위 확인, 소프트 삭제 또는 시점 복구
예방·훈련	소프트 삭제, 이중 확인, 대량 제한, 복원 훈련

M-02 잘못된 배포

발생 가능 원인	테스트 누락, 환경 차이, 결함 코드
탐지 징후	배포 직후 오류율·지연 증가, 헬스 체크 실패
예상 영향	로그인·검색·등록 중단
즉시 대응	배포 중단, 정상 버전 롤백, 기능 플래그 차단
예방·훈련	카나리, 자동 검증, 작은 배포, 롤백 훈련

M-03 DB 마이그레이션 실패

발생 가능 원인	비호환 스키마, 장시간 잠금, 데이터 예외
탐지 징후	컬럼 오류, 잠금 증가, 구버전 실패
예상 영향	배포 실패, 쓰기 중단, 데이터 손상
즉시 대응	롤백 가능성 확인, 쓰기 제한, 검증 복구 스크립트
예방·훈련	하위 호환, 확장 후 축소, 운영 규모 복제 시험

M-04 설정·기능 플래그 오류

발생 가능 원인	환경변수 오입력, 잘못된 플래그 대상
탐지 징후	특정 환경 실패, 갑작스러운 기능 노출
예상 영향	보안 우회, 미완성 기능 공개, 중단
즉시 대응	이전 설정 복구, 플래그 차단, 변경 범위 확인
예방·훈련	설정 스키마, 승인·감사, 안전한 기본값

M-05 중복 매물과 잘못된 가격·주소

발생 가능 원인	검수 부족, 데이터 연동 오류, 의도적 허위 등록
탐지 징후	유사 매물 증가, 급격한 가격 변화, 신고
예상 영향	검색 품질과 신뢰도 하락
즉시 대응	의심 매물 비공개, 원본 확인, 병합, 이력 보존
예방·훈련	중복 점수, 가격 규칙, 게시 전 검수, 만료

M-06 동시 수정과 경합 조건

발생 가능 원인	여러 사용자의 동시 저장, 재시도 중복
탐지 징후	변경 덮어쓰기, 문의·작업 중복
예상 영향	가격·상태 오류, 중복 알림
즉시 대응	작업 중단, 이력으로 복원, 중복 제거
예방·훈련	버전 번호, 낙관적 잠금, 멍등성 키, 동시성 시험

M-07 백업 실패와 복원 불가

발생 가능 원인	백업 작업·저장소·암호화 키 문제
탐지 징후	작업 실패, 용량 급감, 복원 오류
예상 영향	장애 시 영구 데이터 손실
즉시 대응	새 백업, 별도 위치 복사, 즉시 복원 시험
예방·훈련	복원 성공률 지표, 분리 백업, 정기 복구 훈련

M-08 모니터링 공백과 경고 피로

발생 가능 원인	누락된 지표, 과도한 알림, 채널 장애
탐지 징후	사용자가 먼저 신고, 경고 무시, 데이터 누락
예상 영향	탐지·복구 지연, 장애 확대
즉시 대응	핵심 흐름 수동 점검, 잡음 억제, 중요 채널 복구
예방·훈련	증상 알림, 소유자·런북 연결, 정기 알림 시험

M-09 인증서·비밀키·도메인 만료

발생 가능 원인	갱신 자동화·결제·담당자 문제
탐지 징후	만료 경고, 인증 실패, 자동 갱신 실패
예상 영향	접속·로그인·외부 API 중단
즉시 대응	긴급 갱신·교체, 자동화 수정, 서비스 재시작
예방·훈련	30·14·7일 경고, 자동 교체 검증, 소유자 이중화

M-10 문서 부족과 담당자 부재

발생 가능 원인	인수인계 누락, 한 사람에게 지식 집중
탐지 징후	복구 방법·설정 위치를 모름
예상 영향	작은 장애도 장기화
즉시 대응	변경 중단, 현재 상태 기록, 안전한 우회
예방·훈련	런북, 구조도, 교차 교육, 타 담당자 복구 훈련

05 공통 방어 체계와 훈련 순서

영역	반드시 갖출 것
인증·권한	MFA, 최소 권한, 객체 단위 검사, 세션 폐기
애플리케이션	입력 스키마, 출력 인코딩, 요청 제한, 안전한 업로드
데이터	소프트 삭제, 변경 이력, 암호화, 복원 가능한 백업
배포	자동 테스트, 단계 배포, 기능 플래그, 즉시 롤백
관측	오류율, 지연, 트래픽, 자원, 감사 로그, 외부 API
운영	심각도, 연락 체계, 런북, 공지 양식, 회고
유지보수	의존성, 키·인증서, 권한 검토, 문서 최신화

권장 훈련 순서

- 01 잘못된 배포 후 롤백
- 02 외부 지도 API 타임아웃
- 03 이미지 저장소 오류와 기본 이미지 전환
- 04 DB 느린 쿼리와 검색 제한
- 05 관리자 오삭제와 소프트 삭제 복원
- 06 비밀키 노출 가정과 키 교체
- 07 계정 탈취 의심과 전체 세션 폐기
- 08 백업 데이터의 별도 환경 복원
- 09 트래픽 급증과 요청 제한
- 10 격리 환경의 DDoS 유사 부하와 비상 모드 전환

RUNBOOK 사건 대응 기록 양식

사건 번호와 제목	
심각도	
발생 / 탐지 / 대응 / 복구 시각	
최초 탐지 방법	
사용자 영향	
영향받은 시스템·데이터	
현재 확인된 사실	
확인되지 않은 가정	
즉시 차단 조치	
복구 절차와 결과	
보존한 로그와 증거	
근본 원인	
재발 방지 작업	
담당자와 기한	
공지 내용	

사건 종료 조건

서비스 정상화, 확산 차단, 데이터 정합성 확인, 임시 조치 담당자 지정, 근본 원인 기록, 재발 방지 작업 등록, 경고와 런북 개선을 모두 확인한다.